

TASK 03: CMS VULNERABILITY SCANNING (WORDPRESS / JOOMLA)

The CMS vulnerability scanning task focused on assessing a WordPress target for potential security weaknesses. Using WPScan, the CMS version was verified, outdated plugins were checked, and the target was observed to either not be running WordPress or to lack vulnerable components. This exercise highlighted that third-party plugins and misconfigurations are often the weakest points in CMS security, reinforcing the importance of keeping all components updated and properly configured.

Phase 1: Nikto Web Server Scan on Metasploitable2

```
nikto -h 192.168.56.101
```

```

(hyena@hyena) ~/Arjun
$ nikto -h 192.168.56.101
Nikto v2.5.0

-----
Target IP: 192.168.56.101
Target Hostname: 192.168.56.101
Target Port: 80
Start Time: 2026-04-01 17:54:26 (GMT5)
-----

Server: Apache/2.2.8 (Ubuntu) DAV/2
/: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-x-content-type-header/
Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
/index: Uncommon header 'trn' found, with contents: list.
/index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index'
were found: index.php. See: http://www.wisec.it/sectoo.php?id=4538&dc59415, https://exchange.xforce.ibmcloud.com/vulnerabilities/9215
/: Web Server returns a valid response with junk HTTP methods which may cause false positives.
/: HTTP TRACE method is active, which suggests the host is vulnerable to XST. See: https://cve.org/www-community/attacks/Cross_Site_Tracing
/phpinfo.php: Output from the phpinfo() function was found.
/doc/: Directory indexing found.
/doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
/*=PHP555F2B0-3C32-11d3-A7A9-4C7B08C10B00: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. Se
CGVDB-12184
/*=PHP555F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. Se
CGVDB-12184
/*=PHP555F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. Se
CGVDB-12184
/*=PHP555F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUE Y strings. Se
CGVDB-12184
/phpMyAdmin/changeLog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
/phpMyAdmin/changeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog. Inode: 92462, size: 40540, mtime: Tue Dec 9 22:24:0
2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1415
/phpMyAdmin/changeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
/*test/: Directory indexing found.
/*test/: This might be interesting.
/phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
/icons/: Directory indexing found.
/icons/README: Apache default file found. See: https://www.yesweb.co.uk/apache-restricting-access-to-iconserve/
/phpMyAdmin/: phpMyAdmin directory found.
/phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
/phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://type0.org/
/*wp-config.php# : wp-config.php# file found. This file contains the credentials.
8010 requests: 0 error(s) and 27 item(s) reported on remote host.
End Time: 2026-04-01 17:54:39 (GMT5) (13 seconds)
-----

1 host(s) tested:

(hyena@hyena) ~/Arjun

```

Figure 10 – Nikto scan against Metasploitable2 returning 27 flagged items including outdated Apache, phpMyAdmin exposure, PHP info disclosure, and HTTP TRACE vulnerability

The Nikto scan flagged 27 issues on the target web server including:

- Apache 2.2.8 identified as outdated – current was 2.4.54 at scan time
- phpMyAdmin accessible – should be restricted to authorized hosts only
- PHP info exposure via phpinfo() at /phpinfo.php (CWE-552)
- /doc/ directory browsable – CVE-1999-0678 – potential sensitive data exposure
- HTTP TRACE method active – XST (Cross-Site Tracing) attack vector
- Missing X-Content-Type-Options and X-Frame-Options headers

Phase 2: WPScan on Local WordPress Installation

After going deep on the remote target and finding nothing further interesting, a local WordPress instance was set up and scanned to explore CMS-specific attack surfaces related to plugins and configurations.

```
wpscan --url http://localhost:9090
```

```

(hyena@hyena:~/Kadgun)
$ wpscan --url http://localhost:9090

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.25
Sponsored by Automattic - https://automattic.com/
@wpscan, @ethicalhack3r, @erwan_lz, @brefast

[+] URL: http://localhost:9090/ [r/i]
[+] Effective URL: http://localhost:9090/wp-admin/setup-config.php
[+] Started: Wed Apr 1 18:29:06 2024

Interesting Finding(s):

[+] Headers
Interesting Entries:
- Server: Apache/2.4.46 (Ubuntu)
- X-Powered-By: PHP/8.2.30
Found By: Headers (Passive Detection)
Confidence: 100%

[+] WordPress readme found: http://localhost:9090/readme.html
Found By: Direct Access (Aggressive Detection)
Confidence: 100%

Fingerprinting the version - Time: 00:00:03 ----- (702 / 702) 100.00% Time: 00:00:03
[+] WordPress Version 4.9.4 identified (latest: released on 2024-03-12).
round 2: Most Common Wp includes Query Parameter in Homepage (Passive Detection)
- http://localhost:9090/wp-includes/css/dashicons.min.css?ver=6.9.4
Confirmed By: Common Wp Includes Query Parameter in Homepage (Passive Detection)
- http://localhost:9090/wp-includes/css/buttons.min.css?ver=6.9.4

[!] The main theme could not be detected.

[+] Enumerating All Plugins (via Passive Methods)
[!] No plugins found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
checking Config Backups - Time: 00:00:00 ----- 1337 / 1371 100.00% Time: 00:00:00
[!] No Config Backups found.

[!] No WPScan API token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Apr 1 18:29:25 2024
[+] Requests Done: 1418
[+] Cached Requests: 4
[+] Data Sent: 322,255 B
[+] Data Received: 30,293 B
[+] Memory used: 310,455 MB
[+] Elapsed time: 00:00:13

(hyena@hyena:~/Kadgun)
$

```

Figure 11 – WPScan output on locally hosted WordPress 4.9.4 instance; version identified, no vulnerable plugins found, no config backups exposed

Finding	Value	Notes
WordPress Version	4.9.4 (Latest: 6.5.4)	Outdated core – multiple known CVEs exist
Plugins Found	None detected	Low attack surface in this configuration
Config Backup	None exposed	No wp-config.php backup found
readme.html	Accessible	Version disclosed – should be removed in production
Theme	Not detected	No version fingerprinting possible without API token

Key takeaway: Even without vulnerable plugins, the outdated WordPress core itself represents a significant attack surface. Third-party plugins and misconfigurations remain the most common entry points in CMS environments.